Source: docs\LOGIN_APPEARANCE.md | Export: 11 November 2026

Login appearance and customer mobile contact

Owner controls

Open **Admin → Store Settings → Login Page Appearance** (`/admin/settings`). Desktop and mobile each have their own file picker, preview, optional alt text and horizontal/vertical focal sliders. Select a JPEG, PNG or WebP up to 10 MiB, upload it, adjust the verified preview, then **Save login appearance**. File selection and upload alone never publish. Cancel reloads the saved appearance. Upload failure keeps the selection: retry verification first if the upload might have finished, or choose Upload again to create another immutable upload. Save errors preserve edits and reuse the operation ID for safe retries; if another administrator changed the settings, Cancel reloads the saved revision.

Recommended images:

- **Desktop:** 1200 × 1500 px, approximately 4:5 portrait. The current layout is a tall left-hand area; keep the face near the centre and adjust the focal point while previewing.
- **Mobile/tablet:** 1600 × 700 px, approximately 16:7 landscape banner. The banner is intentionally shallow. Keep the face in the central area; tablet ratios vary with viewport width.

The split follows the existing 1024px CSS breakpoint. The saved focal points become `object-position` values and the image remains proportionate with cover cropping. A native `<picture>` source selects desktop only at that breakpoint; mobile does not request the saved desktop image. The approved original portrait is the device-specific missing/error fallback. The portrait container reserves layout space and authentication stays usable while settings fail or images load.

All existing customer authentication/account screens use this one shared portrait component. New settings are fetched without browser/API caching on mount, refresh, focus/visibility return, and every 30 seconds while visible. Reloading or revisiting shows the saved result immediately after the save transaction succeeds. Cloudinary URLs are versioned and never overwritten, so replacement images have new URLs. The app never deletes old or cancelled uploads automatically. Upload only the actual owner photo through these controls; automated checks use synthetic pixels, never an invented owner photograph.

Trusted storage and API

The existing `/api/catalog` function handles four new authenticated actions: `appearance:get`, `appearance:sign`, `appearance:verify`, `appearance:save`. Every action uses the existing revoked-token check, explicit project audience, `admin: true` claim and enabled `adminAccess/{uid}` check. Mutations recheck the access record inside their Firestore transaction. Browser permission state also disables controls when permissions are paused/revoked; it is not the server's authorization boundary.

Cloudinary signing, image-format/size constraints and trusted metadata lookup are reused. A shared transport handles upload progress. Product-specific product ownership and verified media checks are unchanged. Login uploads have separate `loginAppearanceMedia/{32-character media ID}` tickets and fixed server-chosen destinations `parinaya-silks/login/{desktop|mobile}/{mediaId}`. Tickets record purpose, device, uploader, immutable public ID, timestamps and verification metadata. Product tickets cannot be used as login images or the reverse. The shared daily allowance remains 100 signed uploads per administrator.

`siteSettings/loginAppearance` holds schema version 1, separate desktop/mobile references and safe rendering metadata, revision, operation hash/ID and server audit fields. Save uses revision conflicts and idempotent operation IDs. Only verified media for the correct device/purpose can be saved. Public `GET /api/catalog?appearance=login` exposes only desktop/mobile URL, alt text, width/height and focal points. It does not expose internal media IDs, audit fields, uploader identities, private settings or customer profiles. Browser SDK reads/writes to the settings/media collections are explicitly denied, including direct administrator writes; the trusted API is the only path. No new serverless function or index is introduced.

No additional environment variables are needed. Existing server-only Firebase Admin/Cloudinary credentials and signed upload preset are reused. Never put their secrets into `VITE_*` variables.

Registration contact number

Create Account now requires **Mobile number**, with a labelled country selector defaulting to India (+91), `type=tel`, phone autocomplete and a separate number input. Normal pasted spaces, parentheses, dots and hyphens are accepted. libphonenumber-js validates the selected country's numbering plan and mobile or shared fixed/mobile type, then stores E.164 format (for example `+91` followed by the national mobile number). Invalid, incomplete, empty, extension-bearing or mismatched-country values are rejected before Firebase Auth account creation. Passwords remain unchanged; duplicate registration remains locked during processing.

The private UID profile adds only `mobileNumber: string`. New profile creates require this field, canonical international syntax and the India mobile prefix/length when applicable. Rules validate stored format; country-plan plausibility is checked by the shared client validator. Neither proves reachability or ownership. There is **no OTP, phone login, email verification or mobile verification claim**, and the number is never used for authorization. The

account displays name, email and saved mobile contact.

Existing four-field profiles remain readable and are never rewritten during login. Accounts without a number still sign in; the account shows “Not provided”. Missing-profile recovery requests a real number before creating the new profile. Administrator authentication/provisioning does not require a customer profile or number.

After successful Auth creation, pending **name and normalized mobile only** are retained under a UID-specific `parinaya_pending_customer_profile_v1:{uid}` session-storage key, with an in-memory fallback when storage is unavailable. Passwords and tokens are not added to this recovery storage. This permits recovery after a failed profile save and tab reload. Successful profile creation/read or customer sign-out clears it. Closing the tab also clears session storage. A customer whose Auth account exists must use account recovery, not register again.

Rules and coordinated release

`firestore.rules` must be published with this application update: the earlier allowed-field list rejects `mobileNumber`. The reviewed diff adds the required normalized field for new creates, preserves ownership/exact allowed keys/timestamps and all existing administrator/category/product rules, and explicitly denies direct access to login settings/media. Existing profile reads remain permitted by UID. No index publication is needed.

Deployed rules were read from project `parinaya-silks` and matched the local baseline before editing. Before publication, recheck the deployed ruleset so intervening changes are not overwritten. Use the same release window for rules and the new application; older registration pages omit the newly required contact field and must be refreshed after release. Existing account sign-in and profile reads are unaffected. No rule should be relaxed to accommodate a stale client.

After successful local checks, review/commit this task's files only, publish the reviewed rules to `parinaya-silks` / `(default)`, verify readback, then push `main` to the existing `parinaya-silks/parinaya-silks` GitHub repository that triggers Vercel. Record actual commit/push/deployment results separately. These instructions are not evidence that any release action has succeeded.

Validation and production acceptance

Run `npm.cmd run lint`, `npm.cmd test`, `npm.cmd run build`, `npm.cmd run test:catalog-runtime` and `npm.cmd run test:admin`. The emulator suite now includes appearance API/rules tests, the customer mobile/recovery/legacy flows, appearance browser checks, and existing admin/category/product regressions. Cloudinary uploads and returned metadata are fixtures; Auth and Firestore are loopback emulators. The pre-existing password-policy endpoint fixture is retained because Firebase CLI 15.34 does not implement that endpoint. No dummy production users or live image uploads are needed for these tests.

Coverage includes dual admin authorization, ordinary/partial-admin denial, cross-purpose/device media rejection, unverified upload rejection, idempotent save, stale revision, revocation, public projection, direct settings/media denial, upload/settings/save failures and retry, unpublished selection/upload, Cancel/reload, responsive device loading/focal points/fallback at 320/375/390/768/1024/1440px, invalid-mobile prevention before Auth signup, canonical private storage, profile isolation, failed-profile-save recovery after reload, legacy sign-in, email/password/reset/persistence and existing catalog workflows.

After Vercel reports Ready for the pushed commit, verify `/login`, `/register`, the public appearance GET and signed-out `/admin/settings`. Compare mobile/desktop layouts without creating production test accounts. The owner should sign in to Admin, upload their real desktop/mobile photos, Save, revisit and verify the actual face crop on their devices. Real Cloudinary preset behavior, owner-image quality, actual phone-keyboard/safe-area behavior and a real authorized admin save require owner production acceptance; emulator fixtures do not establish these results.

Changed implementation groups: `src/appearance/`, `server/loginAppearance.ts`, catalog handler/service, shared Cloudinary ticket/transport, admin panel settings routing, shared AuthFrame/CSS, customer mobile field/validator/pending recovery/profile/service/screens, Firestore rules, targeted unit/emulator/browser tests and this guide. Existing branding assets are retained.

Local results: TypeScript, 54 unit tests, production build, packaged Vercel function invocation, all five emulator rule/service suites and customer/appearance/admin/category/product browser suites passed. `python scripts/login-layout.test.py` also passed against production preview on port 4173 with all backend calls intercepted, covering registration at six widths and invalid-mobile rejection before any Auth request. Existing production deployment inspection and Git push preflight were available under the verified `parinaya-silks` scope/repository. Actual rule publication, push and new deployment results are reported in the handoff after release.